Zamp AP — Autonomous Vendor Onboarding Intelligence

System Architecture, Risk Engineering & Verification Capabilities Report (Problem Statement 2)

Core Architectural Principle: Rules Decide, the LLM Only Communicates.
In enterprise Accounts Payable, automated money movement and vendor enablement demand 100% deterministic, auditable, and reproducible decisions. This engine executes 6 automated validation stages plus a weighted decision & risk-scoring gate using mathematical checksums, semantic entity normalization, and BEC fraud heuristics. An LLM (Gemini 3.5 Flash-Lite) is never allowed to decide approval or rejection; it operates strictly behind safety guardrails solely to compose polite vendor correspondence.

1. Key Project Strengths at a Glance

Capability Pillar	Why It Stands Out
Deterministic Decisioning	Every rule emits a structured effect tag (*none / fix / review / block*). Decisions are 100% explainable, fast (~30 ms pipeline latency), and immune to LLM hallucinations.
True Mathematical Checksums	Validates Indian GSTIN (Mod-36 + 38 states + PAN), US ABA routing (FedWire Mod-10), and EU/UK/DE IBANs (ISO 7064 Mod-97) rather than superficial regex pattern checks.
Offline 40-Bank Directory	Maps 40 IFSC, ABA, and SWIFT/BIC prefixes to official bank names without external API failure risk, catching mismatched bank names vs. routing codes automatically.
Smart Entity Normalization	Strips 24 global corporate suffixes (*Pvt Ltd, LLC, GmbH, Inc, Sarl*) and runs dual SequenceMatcher similarity so valid suffix variants pass while third-party mule accounts are stopped.
BEC & Account-Takeover Defense	Detects bank-detail changes and look-alike domains on active ERP vendors, mandates out-of-band phone callback, and routes confirmation emails strictly to the **contact ON FILE**—never the submitter.
Differential Resubmission Diffing	Tracks SQLite run history per legal entity and computes exact deltas across attempts: *Resolved*, *Still Open*, and *New Anomalies*.
0–100 Composite Risk Score	Aggregates severity and fraud signals into Low / Medium / High / Critical risk bands with a visual progress gauge for instant ops triage.
Guardrailed LLM + Fallback	Uses Gemini 3.5 Flash-Lite (with multi-model fallback) behind 9 forbidden-term filters, account-number redaction, and deterministic template fallback so onboarding never halts.
Zero-Setup Executive Dashboard	Auto-seeds all 9 benchmark runs on first launch with live KPIs, top failure charts, status/vendor filtering, and one-click Deep Inspection replay.

2. Multi-Stage Verification Architecture

Stage	Verification Focus	Core Logic & Cross-Checks	Decision Effect
1. Intake	Mandatory fields & 3 compliance docs	Validates company/banking inputs, dynamic jurisdiction-aware bank code requirement (IN/US/GB), RFC-style email format, and 3 required documents.	Missing → **PENDING (Fix)**
2. Tax ID	Checksums & jurisdiction extraction	Runs GSTIN Mod-36 checksum (plus state name & PAN extraction), IRS EIN prefix validation, and UK/DE VAT + SG UEN verification. Detects valid foreign tax IDs.	Bad check → **Fix** Foreign ID → **Stage 5**
3. Bank Detail	Routing math & semantic bank lookup	Executes IFSC/ABA Mod-10/IBAN Mod-97 checks, resolves bank code via 40-institution offline directory, and checks ≥60% similarity with declared bank name.	Bad format → **Fix** Name clash → **Review**
4. Payee Match	Entity resolution & mule detection	Prunes 24 legal suffixes, normalizes punctuation, and compares sorted & linear token similarity (≥90% pass, 70–89% partial review, <70% mule alert).	≥90% → **PASS** <90% → **Review**
5. Cross-Field	Multi-attribute consistency	Matches Tax ID country vs. vendor country, flags offshore bank countries, verifies country postal codes (PIN/ZIP/PLZ/postcode), and checks domain-name alignment.	Country clash → **Review** Free-mail → **Advisory**
6. Registry	Watchlist, duplicates & BEC	Screens internal fraud/debarment watchlist (account, tax ID, normalized name), detects duplicate active vendors, and flags bank changes or look-alike domains.	Watchlist/Dup → **REJECT** Bank change → **Review**
7. Decision	Risk scoring & dispatch	Aggregates block/review/fix signals into APPROVED, PENDING, or REJECTED, computes 0–100 risk score, runs resubmission diffing, and dispatches email.	ERP Enable, Hold, or Stop

3. Mathematical Checksums & Offline Banking Intelligence

Simple regular expressions only check character shape, allowing transposed digits to enter Accounts Payable. This engine validates true check digits across major payment corridors:

• Indian GSTIN (Luhn-Variant Mod-36 + State & PAN Extraction):

Applies alternating weights (1, 2) in base-36 across the first 14 characters to verify the 15th check digit, validates against all 38 official Indian GST state codes (e.g., 36 → Telangana, 27 → Maharashtra), and isolates the embedded 10-character PAN.

• US FedWire ABA Routing (Weighted Mod-10) & European IBAN (ISO 7064 Mod-97):

Verifies 9-digit US routing numbers via (3·d1 + 7·d2 + 1·d3 + ... + 1·d9) mod 10 = 0, and transforms EU/UK/DE IBANs into integer streams enforcing (N mod 97 = 1).

• Offline 40-Institution Bank Registry & Semantic Mismatch Detection:

Embeds 40 verified prefixes (20 Indian IFSC codes such as SBIN, HDFC, ICIC, UTIB; 10 US ABA prefixes such as 0210 JPMorgan Chase, 0260 Bank of America; and 10 SWIFT/BIC codes across SG, DE, GB). Even if a vendor enters a valid checksum, declaring 'HDFC Bank' alongside an 'SBIN...' IFSC triggers an immediate semantic bank-name review flag—with zero third-party API dependency.

4. Business Email Compromise (BEC) Defense & LLM Guardrails

Invoice and bank-change redirection is one of the costliest AP attack vectors. When an active vendor's Tax ID matches the master registry but presents a new bank account (such as **Orion Industrial Supplies GmbH** submitting a new IBAN from look-alike domain *orion-industrial.co* instead of *orion-industrial.de*):

1. **Pending Hold Instead of Hard Reject:** Avoids blocking legitimate treasury switches while freezing automated payouts.
2. **Safe Target Routing:** Confirmation emails are routed strictly to the **verified email ON FILE** (*procurement@orion-industrial.de*), never the incoming submitter, preventing an attacker with a spoofed or compromised mailbox from confirming the redirect.
3. **Zero-Leak Watchlist Declines:** Debarred or fraud-linked submissions receive a neutral decline without revealing detection logic.
4. **Sanitized LLM Dispatch (Gemini 3.5 Flash-Lite):** The LLM receives only vendor-safe facts (never internal fraud flags or watchlist notes), passes output through 9 forbidden-keyword checks (*watchlist, blocklist, fraud, suspicious, sanction, debar, mule, risk score, compromise*) plus account-number leakage checks, and falls back across *gemini-3.8-flash* / *gemini-2.5-flash-lite* or deterministic templates on any failure.

5. Composite Risk Scoring & Verified Scenario Benchmarks

The engine synthesizes every check into a bounded 0–100 Composite Risk Score (**0–20 Low**, **21–45 Medium**, **46–70 High**, **71–100 Critical**): base severity adds +40 for *block*, +20 for *review*, and +10 for *fix*, layered with fraud-specific multipliers (+50 watchlist, +25 bank change, +20 look-alike contact domain, +15 offshore bank country, +5 free mailbox).

Scenario	Decision	Checks	Risk Score	Key Judgment Demonstrated
Happy Path (Apex Cloud, IN)	APPROVED	15/15	0 / Low	GSTIN Mod-36 + state 36, IFSC → HDFC match, PIN & domain verified.
Edge 1a (Green Valley, IN)	APPROVED	15/15	0 / Low	Normalizes 'Private Limited' vs 'PVT LTD' without false friction.
Edge 1b (Brightpath, US)	PENDING	13/14	20 / Low	Valid ABA 0210 (Chase), catches third-party payee 'Sunrise Trading Co'.

Scenario	Decision	Checks	Risk Score	Key Judgment Demonstrated
Edge 2 (Sterling Bridge, GB)	PENDING	11/14	55 / High	Detects Indian GSTIN & Axis Bank on a claimed UK incorporation.
Edge 3 (Orion Supplies, DE)	PENDING	13/15	85 / Critical	BEC bank change + .co look-alike domain; email routed to contact ON FILE.
Edge 4a (Nimbus Labs, US)	PENDING	8/11	30 / Medium	Missing email, missing bank proof, invalid IRS EIN prefix '07'.
Edge 4b (Nimbus Resubmit)	PENDING	12/13	10 / Low	Delta engine isolates 2 Resolved items vs 1 Still Open bad EIN.
Bonus (Quickpay, SG)	REJECTED	12/14	100 / Critical	Hard-stops fraud-linked account 0721983456; neutral zero-leak email.
Bonus (Kestrel, GB)	REJECTED	11/12	40 / Medium	Prevents duplicate ERP record creation for active vendor V-1010.

6. Scope Boundaries & Enterprise Production Roadmap

The prototype intentionally maintains clear engineering boundaries while keeping integration seams clean for production:

• **Live Tax & Entity Registries:** Mathematical checksums and prefix tables serve as fast local gates; production connects directly to GSTN (India), IRS TIN Matching (US), EU VIES, and ACRA (Singapore).

• **Account Ownership Verification:** Algorithmic entity resolution pairs cleanly with real-time penny-drop APIs (RazorpayX / Cashfree) and UK/EU Confirmation of Payee.

• **Document OCR & Persistence:** Uploaded document checklists upgrade directly to multimodal OCR extraction against form fields, backed by PostgreSQL + analyst SLA queues in place of ephemeral SQLite.